Actividad en equipos: Políticas de gestión de las TI, disposiciones legales y reglamentarias, normas y políticas de uso

1. Objetivo de aprendizaje

Analizar la importancia de las políticas de gestión de las Tecnologías de Información (TI), las disposiciones legales y reglamentarias aplicables, así como las normas y políticas de uso, mediante el diseño de un conjunto de políticas institucionales que promuevan la seguridad de la información, el uso responsable de los recursos tecnológicos, el cumplimiento normativo y la continuidad de las operaciones de una organización.

2. Situación problemática

Una organización ha identificado diversos problemas relacionados con el uso de sus recursos tecnológicos:

- Los empleados comparten contraseñas para acceder a los sistemas institucionales.
- Algunos usuarios instalan software sin autorización.
- Se utilizan dispositivos personales para almacenar información confidencial.
- No existen reglas claras para el uso del correo electrónico, internet y los servicios de almacenamiento en la nube.
- Se han presentado incidentes de seguridad por correos electrónicos fraudulentos.
- La organización almacena datos personales de clientes y empleados sin procedimientos documentados para su protección.
- No existen políticas definidas para realizar respaldos, administrar permisos de acceso o responder ante incidentes informáticos.

La dirección de la organización solicita al área de TI desarrollar un Manual de Políticas de Gestión de las Tecnologías de Información, que permita establecer reglas, responsabilidades y procedimientos para atender estos problemas.

Cada equipo deberá asumir el papel de un departamento de consultoría tecnológica encargado de elaborar la propuesta.

3. Organización de los equipos

Cada equipo deberá seleccionar una organización real o ficticia. Se recomienda elegir una de las siguientes:

Equipo 1. Institución educativa

Universidad o facultad que administra expedientes académicos, plataformas educativas, correo institucional y laboratorios de cómputo.

Equipo 2. Hospital privado

Organización que utiliza sistemas de información clínica, datos personales y equipos conectados a una red institucional.

Equipo 3. Empresa comercial

Empresa que administra ventas, inventarios, proveedores, clientes y transacciones mediante un sistema ERP o CRM.

Equipo 4. Empresa de desarrollo de software

Organización que administra código fuente, repositorios, bases de datos, servicios en la nube y credenciales de acceso.

4. Desarrollo de la actividad

Fase 1. Diagnóstico de la organización

Cada equipo deberá identificar los recursos tecnológicos de la organización seleccionada y los principales riesgos asociados con su uso.

El diagnóstico debe incluir:

- Hardware: computadoras, servidores, dispositivos móviles y equipos de red.
- Software: sistemas operativos, aplicaciones, sistemas administrativos y plataformas digitales.
- Información: datos personales, información financiera, expedientes y documentos institucionales.
- Usuarios: empleados, administradores, directivos, proveedores y clientes.
- Servicios tecnológicos: internet, correo electrónico, almacenamiento en la nube y sistemas de información.

Posteriormente, elaboren una tabla de diagnóstico.

Problema identificado	Riesgo para la organización	Política requerida
Contraseñas compartidas	Acceso no autorizado	Política de control de acceso
Software sin licencia o autorización	Riesgo legal y de seguridad	Política de instalación de software
Ausencia de respaldos	Pérdida de información	Política de copias de seguridad
Uso inadecuado de datos personales	Incumplimiento normativo	Política de protección de datos
Correos fraudulentos	Robo de credenciales	Política de seguridad del correo

Fase 2. Investigación de disposiciones legales y reglamentarias

Cada equipo deberá investigar las disposiciones que podrían ser aplicables a la organización seleccionada, explicar su relación con la gestión de TI y señalar qué obligaciones o medidas concretas implican.

Como referencia para el contexto mexicano, consideren las siguientes disposiciones, verificando su vigencia y aplicabilidad según el tipo de organización:

Disposición	Relación con la gestión de TI
Ley Federal de Protección de Datos Personales en Posesión de los Particulares	Protección de datos personales en organizaciones privadas.
Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados	Tratamiento de datos personales por sujetos obligados del sector público, conforme a su ámbito de aplicación.
Ley Federal del Derecho de Autor	Protección de programas de cómputo y otras obras protegidas.
Código Penal Federal y legislación penal aplicable	Conductas relacionadas con acceso ilícito, alteración o afectación de sistemas y datos, según el supuesto legal.
Ley Federal del Trabajo, cuando corresponda	Aspectos laborales relacionados con el uso de recursos tecnológicos y las responsabilidades del personal.
Contratos, licencias y acuerdos de confidencialidad	Condiciones de uso de software, servicios digitales e información institucional.

Además, deberán investigar normas y marcos de referencia que apoyen la gestión de TI:

- ISO/IEC 27001: sistema de gestión de seguridad de la información.

- ISO/IEC 27002: controles de seguridad de la información.
- ISO/IEC 20000-1: gestión de servicios de TI.
- COBIT: gobierno y gestión de las tecnologías de información.
- ITIL: prácticas para la gestión de servicios de TI.

Es importante distinguir entre las leyes y disposiciones obligatorias, las normas cuyo cumplimiento resulte exigible por regulación o contrato, y los marcos de referencia o buenas prácticas que una organización puede adoptar voluntariamente.

El equipo deberá registrar, para cada fuente, su nombre oficial, versión o fecha, ámbito de aplicación, obligación o recomendación relevante y enlace a una fuente oficial o confiable. No basta con copiar definiciones.

Fase 3. Diseño de políticas de gestión de TI

Cada equipo elaborará al menos ocho políticas institucionales. Para cada una, deberá definir el propósito, alcance, responsables, reglas de cumplimiento y medidas de seguimiento.

Se proponen las siguientes categorías:

1. Seguridad de la información

Clasificación de la información, confidencialidad, integridad, disponibilidad y manejo de incidentes.

2. Control de acceso y contraseñas

Cuentas individuales, autenticación multifactor cuando proceda, privilegios mínimos y baja de usuarios.

3. Uso aceptable de equipos y software

Instalación autorizada de aplicaciones, licenciamiento, mantenimiento y uso de dispositivos personales.

4. Protección y privacidad de los datos

Acceso, almacenamiento, transferencia, conservación y eliminación segura de información personal o confidencial.

5. Uso del correo electrónico e internet

Prevención del phishing, manejo de archivos adjuntos, navegación segura y comunicación institucional.

6. Servicios en la nube y dispositivos móviles

Uso de plataformas aprobadas, sincronización, permisos de compartición y protección de dispositivos.

7. Respaldos y continuidad operativa

Frecuencia de respaldos, almacenamiento protegido, pruebas de recuperación y responsables de continuidad.

8. Cumplimiento, auditoría y capacitación

Revisión periódica de accesos, capacitación de usuarios, registro de incidentes y evaluación del cumplimiento.

Fase 4. Elaboración de una política documentada

Cada equipo deberá desarrollar de manera completa dos de sus políticas, utilizando la siguiente plantilla.

Elemento	Descripción requerida
Nombre de la política	Título claro y específico.
Código y versión	Identificador, por ejemplo, POL-TI-01, y número de versión.
Objetivo	Resultado que se pretende alcanzar.
Alcance	Usuarios, áreas, sistemas y recursos a los que aplica.
Fundamento	Disposiciones legales, contractuales, normas o buenas prácticas pertinentes.
Responsables	Área de TI, dirección, usuarios y responsables de protección de datos, según corresponda.
Reglas de uso	Conductas permitidas, restringidas y prohibidas.
Procedimiento	Acciones para aplicar la política y reportar incumplimientos.
Seguimiento	Indicadores, evidencias y frecuencia de revisión.
Consecuencias	Medidas correctivas conforme a las disposiciones y procedimientos aplicables.

Ejemplo de política: uso de contraseñas y cuentas institucionales

- Objetivo: reducir el riesgo de accesos no autorizados.
- Alcance: todos los usuarios que accedan a los sistemas institucionales.
- Reglas: cada usuario deberá utilizar una cuenta individual, mantener sus credenciales bajo resguardo, evitar compartirlas y utilizar autenticación multifactor cuando esté disponible y sea apropiada.

- Responsables: el área de TI administrará los mecanismos de acceso; los usuarios protegerán sus credenciales y reportarán incidentes.
- Seguimiento: revisión trimestral de cuentas activas y privilegiadas, y verificación del cumplimiento de los controles establecidos.
- Respuesta ante incidentes: reportar inmediatamente la sospecha de compromiso de una cuenta para que se apliquen las medidas de contención y recuperación.

El equipo deberá adaptar este ejemplo a su organización y fundamentar las reglas propuestas.

Fase 5. Presentación y discusión

Cada equipo realizará una exposición de entre 5 y 7 minutos que incluya:

1. Descripción de la organización y sus principales riesgos tecnológicos.
2. Disposiciones legales y reglamentarias aplicables.
3. Normas y marcos de referencia seleccionados.
4. Presentación de las ocho políticas propuestas.
5. Explicación de dos políticas desarrolladas en detalle.
6. Beneficios esperados y mecanismos para evaluar el cumplimiento.

Al finalizar, los demás equipos formularán preguntas y sugerencias. Cada equipo deberá justificar por qué sus políticas son pertinentes y cómo contribuyen a la gestión responsable de las TI.

5. Estructura del producto final

El manual deberá entregarse en formato Word o PDF con la siguiente estructura:

1. Portada institucional.
2. Introducción.
3. Descripción de la organización seleccionada.
4. Diagnóstico de riesgos tecnológicos.
5. Marco legal y reglamentario.
6. Normas y marcos de referencia.
7. Catálogo de ocho políticas de gestión de TI.
8. Desarrollo detallado de dos políticas.
9. Responsables e indicadores de cumplimiento.
10. Conclusiones.
11. Referencias bibliográficas y fuentes oficiales consultadas.

6. Evaluación de la actividad

Se propone la siguiente rúbrica de evaluación, con un valor total de 100 puntos.

Criterio	Ponderación
Diagnóstico de la organización y sus riesgos	15 puntos
Investigación y pertinencia del marco legal	20 puntos
Aplicación de normas y marcos de referencia	15 puntos
Calidad y viabilidad de las políticas propuestas	25 puntos
Indicadores y mecanismos de seguimiento	10 puntos
Calidad del documento y referencias	5 puntos
Exposición y colaboración del equipo	10 puntos
Total	100 puntos

Criterios de desempeño

- Excelente: propuestas claras, viables, justificadas y relacionadas con los riesgos y obligaciones identificados.
- Satisfactorio: propuestas pertinentes, pero con algunos elementos incompletos o poco desarrollados.
- Básico: políticas generales con escasa justificación legal o técnica.
- Insuficiente: propuestas incompletas, sin relación clara con los problemas de la organización o sin fuentes verificables.